



Round 2 – System Integrity Audit Report

Team-Aegis

Team Members:

- Amogh Neeli
- Athish Satish Naidu R
- Saamarth S
- Samarth S Prabhu

Problem Statement-Digital Safety Toolkit for Women in High-Risk Professions

Real-Time Detection of Hidden Cameras and Trackers

1. Round 1 Solution Overview

- A compact, fully portable hardware-software solution, which is able to independently detect hidden cameras and BLE tracking devices in any given area, without human intervention
- The system addresses a critical gap in personal safety solutions currently offered on the market by existing detection tools that are manual, single-vector and thus cannot detect wired cameras that emit no RF signals. Thus, victims are generally unaware of the existence of such surveillance tools until serious physical or property harm has already occurred.
- Our primary user is women from high-risk professions (e.g. journalist, activist, business woman etc.) who are frequently subject to covertly-installed hidden cameras in their hotel rooms, rented apartments and even in their own offices at work.
- The system operates through three core functions. First, it actively scans for RF signals from wireless hidden cameras and rogue tracking devices like AirTags. Second, it uses an IR red-light emitter to detect lens reflections from wired cameras invisible to RF scanning. Third, it learns the RF baseline of a room on first entry and automatically flags any new unknown signal on re-entry.
- Two on-device AI models process sensor data in real time, an RF anomaly classifier that filters out benign devices, and a computer vision model that distinguishes actual camera lenses from mirrors and reflective surfaces based on reflection patterns and brightness.

- Detected threats are immediately pushed to a mobile dashboard with directional guidance pointing the user toward the threat source.
- In a real-world environment, the device operates silently in the background that is plugged into a wall or carried in a bag that continuously monitoring without requiring the user to actively initiate any scan.
- The expected impact is a shift from reactive, manual detection to proactive, autonomous protection for individuals in high-risk environments.

2. Original System Architecture

Hardware Layer

- The physical device is built on a microcontroller, serving as the central processing unit that aggregates all sensor inputs.
- RF modules scanning across 433MHz, 2.4GHz, and 5GHz bands continuously sniff for wireless hidden camera signals and rogue BLE tracking devices.
- An IR LED array emits high-frequency red light toward surfaces in the environment, a paired photodetector captures reflection patterns to identify camera lens signatures.

Spatial Memory Engine

- On first entry to a room, the device performs a full RF scan and stores the environment's signal baseline as an RF fingerprint in a local SQLite database.
- On every subsequent entry, live RF readings are compared against the stored fingerprint; any new unrecognized signal automatically triggers an alert.
- This module operates entirely on-device with no cloud dependency, ensuring user data privacy.

AI Inference Layer

- Two lightweight models run on device via TensorFlow Lite.
- The RF anomaly classifier is trained to distinguish benign device signals such as phones, routers, laptops from known surveillance device RF signatures, eliminating false positives.
- The computer vision model processes IR reflection data using OpenCV to differentiate actual camera lenses from mirrors, lamp glass, and other reflective surfaces based on reflection geometry and brightness patterns.

Threat Evaluation and Localization

- Outputs from both AI models are cross-referenced with the spatial memory delta to produce a unified threat score.
- Signal strength gradients across sensors are tracked to generate step by step directional instructions pointing toward the threat source.

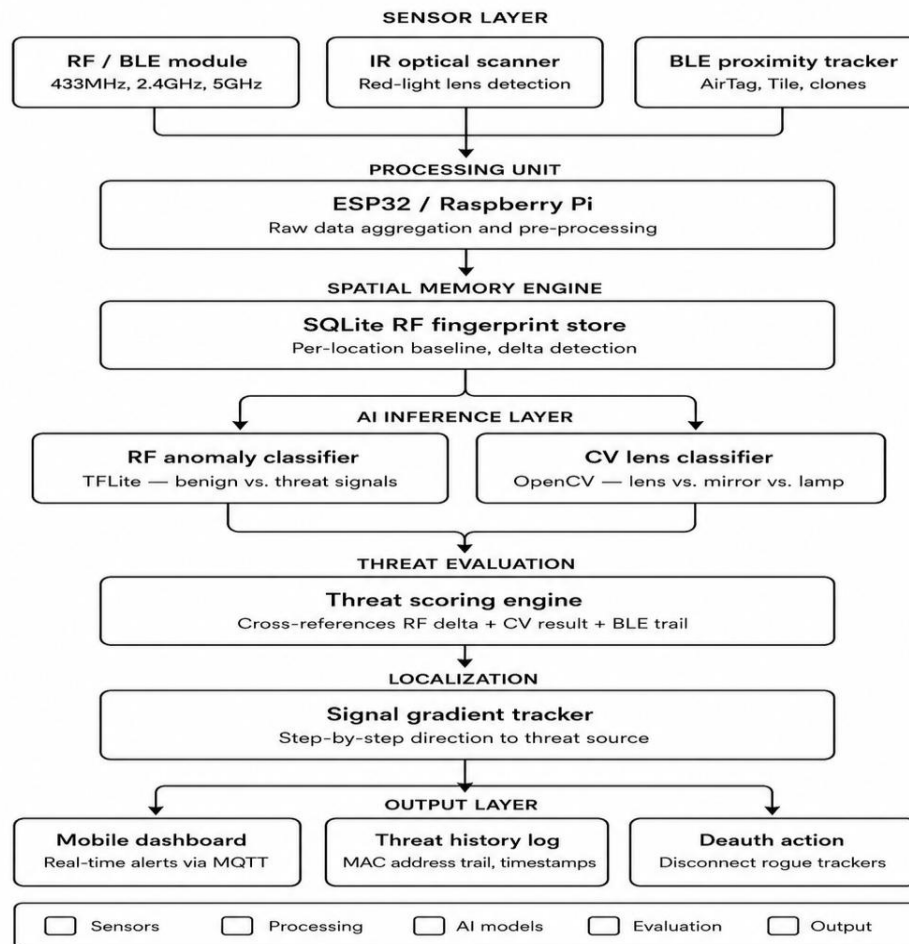
Communication and Output Layer

- Threat events are published to a mobile dashboard via the MQTT protocol for lightweight, real-time transmission.

- The mobile application, built in Flutter or React Native, displays live alerts, threat history, flagged MAC addresses, and cross-location BLE tracking patterns.
- The system can also trigger automated de-authentication of unrecognized BLE trackers attempting to ping the user's location.

Module Interaction Flow

- Sensors → ESP32 aggregation → Spatial memory comparison → AI inference → Threat scoring → Directional guidance → MQTT → Mobile dashboard.



3. Threat Surface & Vulnerability Analysis

- The SQLite database storing RF fingerprints and threat history is held locally on the ESP32 or Raspberry Pi with no encryption layer. If the device is stolen or tampered with, an attacker gains full access to the user's location history and behavioural patterns that particularly dangerous for journalists and activists whose location data is itself a high-value surveillance target. **[High Risk]**
- MQTT by default transmits data without encryption. If the broker is not configured with TLS, all threat alerts, MAC addresses, and device logs transmitted between the hardware and mobile dashboard are exposed to interception. A man-in-the-middle attack on an

unsecured hotel or public Wi-Fi network could allow an adversary to monitor device activity or inject false alerts into the dashboard. **[High Risk]**

- The mobile application has no described authentication or authorization mechanism. Without user authentication, any person with access to the device or MQTT broker can view threat logs, location fingerprints, and alert history, directly compromising user privacy. **[Medium Risk]**
- The RF anomaly classifier and CV lens detection model are susceptible to adversarial inputs. A sophisticated attacker could emit RF signals mimicking benign devices to evade detection, or use anti-reflective surfaces to avoid triggering the lens classifier. Over-reliance on model confidence without a fallback layer increases the risk of missed threats. **[Medium Risk]**
- Modern BLE devices including AirTags use MAC address randomization. The system's tracker detection logic based on MAC address persistence may fail against devices that rotate their address, producing false negatives for active tracking attempts. **[Medium Risk]**
- The device has no described tamper detection or secure boot mechanism. An adversary with brief physical access could flash modified firmware, disable detection entirely, or plant a backdoor. **[Medium Risk]**
- Highly reflective everyday surfaces such as glasses, metallic objects, and polished furniture may generate false positive lens detections, eroding user trust over repeated use. **[Low Risk]**
- The SQLite database will grow over time across multiple locations with no pruning mechanism, potentially degrading performance on memory-constrained hardware. **[Low Risk]**

4. Attack & Misuse Scenarios

1. RF Signal Spoofing to Evade Detection

- A technically sophisticated attacker planting a surveillance device could deliberately program it to emit RF signatures identical to benign devices such as routers or Bluetooth keyboards.
- The RF anomaly classifier, trained on known surveillance signatures, would classify the device as safe and produce no alert.
- Impact: Complete evasion of the primary detection layer, leaving the user with a false sense of security.

2. Man-in-the-Middle Attack on MQTT Channel

- In a hotel or shared network environment, an attacker on the same Wi-Fi network intercepts unencrypted MQTT traffic between the device and the mobile dashboard.
- The attacker gains access to real-time threat alerts, to flagged MAC addresses, to the complete RF fingerprints of all connected devices, as well as to the user's location patterns in real time.
- Impact: The very data collected to protect the user becomes a surveillance tool against them.

3. Physical Device Theft and Data Extraction

- An adversary potential the same person who planted the surveillance device that stole or briefly accessed the hardware.
- The absence of encryption on the SQLite database information that is gathered by the system can be extracted by an adversary (e.g. the person who planted the spy device or a thief to the hardware for a short period of time) and include a full RF fingerprint history for the user, including all locations visited and information about all of the user's personal devices including signal profiles.
- Impact: Full compromise of location history as well as of personal identifiers of his/her devices.

4. Adversarial Optical Surfaces Defeating CV Model

- A hidden camera is concealed behind a surface specifically engineered to suppress or scatter IR reflection, such as anti-reflective coated glass or matte black housing.
- The CV lens classifier fails to detect a reflection pattern and classifies the surface as safe.
- Impact: Wired camera detection fails entirely, eliminating the system's advantage over RF-only tools.

5. False Alert Flooding via RF Jamming

- An attacker nearby intentionally saturates the 2.4GHz band with noise or fake BLE beacon packets.
- The system frequently triggers false positive alerts, which frustrate the user and gradually undermine confidence in the device, leading to real alerts being disregarded.
- Impact: Denial of service to the detection system itself, caused by alert fatigue.

Secure Redesign & Improvements

- The SQLite database storing RF fingerprints and threat history must be encrypted using AES-256 at rest, with a device-specific key stored in the hardware's secure enclave. If the device is stolen, extracted data remains unreadable without the key.
- All communication between the hardware and mobile dashboard must be secured with TLS 1.3 over MQTT, with certificate-based mutual authentication ensuring only the paired application can receive data.
- The mobile dashboard must require biometric or PIN-based authentication before granting access to threat logs and location data, with an automatic session timeout locking the app after inactivity.
- The firmware must implement a secure boot chain verifying software integrity at startup. A physical tamper detection mechanism should trigger an automatic data wipe if the device casing is opened without authorization.
- A rule-based fallback layer must operate alongside the AI models to counter adversarial evasion. When a signal or reflection falls below the model's confidence threshold, deterministic heuristics signal persistence, frequency anomalies, reflection intensity make an independent secondary classification decision, reducing false negatives.

- Instead of relying on MAC addresses which can be faked or changed by BLE trackers should focus on recognizing devices when the MAC address changes, the device still behaves the same way as its signal strength, how often it advertises, and the structure of the data it sends all stay consistent. That means you can reliably spot the same physical device, no matter how many.
- We need a smart alert filter that groups repeated alerts from the same frequency band into one unified threat event, this helps prevent operators from getting overwhelmed by flood of false alarms caused by RF jamming attacks.
- Stored RF fingerprints must support periodic recalibration to account for legitimate environmental changes, with explicit user confirmation required to prevent an attacker from silently overwriting the baseline to conceal a planted device

5. Final Audit Summary

- We provide a genuinely novel approach to personal surveillance detection, combining hardware sensing, spatial memory, and on-device AI into a single autonomous system.
- However, in its original design, the system carries significant security gaps that make it unsuitable for deployment in its current state. The two most critical risks are unencrypted local data storage and an unsecured MQTT communication channel between both of which could turn the system's own collected data into a tool against its users.
- Additional medium-severity vulnerabilities around mobile authentication, physical tamper protection, BLE MAC randomization handling, and AI model evasion further reduce deployment readiness.
- The proposed redesign covering database encryption, TLS-secured MQTT, biometric app authentication, secure boot, hybrid AI fallback, and behaviour-based BLE tracking directly addresses every identified vulnerability.
- Following full implementation of the recommended improvements, can be considered secure, privacy-preserving, and ready for real-world deployment in high-risk environments.

References

- Kolias, C., Kambourakis, G., Stavrou, A., & Voas, J. (2017). DDoS in the IoT: Mirai and other botnets. *IEEE Computer*, 50(7), 80–84.
- Acar, G., Eubank, C., Englehardt, S., Juarez, M., Narayanan, A., & Diaz, C. (2014). The web never forgets: Persistent tracking mechanisms in the wild. *ACM CCS 2014*.
- OWASP IoT Attack Surface Areas Project. (2023). Retrieved from <https://owasp.org/www-project-iot-security/>
- MQTT Protocol Specification v5.0. (2019). OASIS Standard. Retrieved from <https://mqtt.org/mqtt-specification/>



- TensorFlow Lite. (2024). On-device machine learning for mobile and edge devices. Google Developers. Retrieved from <https://www.tensorflow.org/lite>
- OpenCV Documentation. (2024). Open source computer vision library. Retrieved from <https://docs.opencv.org>
- National Institute of Standards and Technology. (2023). *NIST Cybersecurity Framework 2.0*. U.S. Department of Commerce.
- SQLCipher. (2024). Open source full database encryption for SQLite. Zetetic LLC. Retrieved from <https://www.zetetic.net/sqlcipher/>
- Bluetooth Special Interest Group. (2022). *Bluetooth Core Specification v5.3 — Privacy and MAC address randomization*. Retrieved from <https://www.bluetooth.com/specifications/>
- European Union Agency for Cybersecurity (ENISA). (2023). *Good Practices for IoT Security*. Retrieved from <https://www.enisa.europa.eu>